

Incident Report: Cross-Site Request Forgery (CSRF)

Incident Details:

- **Date & Time:** February 17, 2025, at 10:59 AM
- **Source IP:** ()
- **Source Port:** 39621
- **Destination IP:** () – Finance Web Server
- **Destination Port:** 443 (HTTPS)
- **Targeted Website:**
- **Targeted URL:** /accounts/delete?user=1
- **Attack Type:** Cross-Site Request Forgery (CSRF)
- **HTTP Method:** GET
- **Response Code:** 200 (Request Allowed)
- **User-Agent:** Mozilla/5.0 (Macintosh; Safari)
- **Threat Severity:** High
- **Action Taken:** Request Allowed (Logged by WAF in monitoring mode)

Incident Summary:

On **February 17, 2025**, a **CSRF attack attempt** was observed targeting . The malicious request from IP attempted to delete a user account (/accounts/delete?user=1) using an HTTP GET request.

The Web Application Firewall (WAF) detected the request but did not block it (HTTP 200 response returned). This indicates that if the application does not implement CSRF defenses, attackers could potentially perform unauthorized actions on behalf of authenticated users.

Targeted System:

- **Server Name:**
- **IP Address:**
- **OS:** RHEL 8
- **Function:** Finance Department Web Server (VM)
- **Criticality:** Low (as per asset classification)
- **Ownership:** Finance Department (Head of Finance)
- **Custodian Team:** Team

IP Reputation Analysis:

The source IP (**110.22.190.227**) currently shows no record of malicious activity in threat intelligence feeds. However, due to the nature of the attempt, it should remain under observation.

Analysis:

- **Nature of Attack:** CSRF tricks authenticated users into executing unintended requests.
- The attempt targeted **/accounts/delete?user=1**, aiming to delete a user account without explicit authorization.
- The **HTTP 200 response** confirms that the request was processed successfully. This strongly suggests the application may lack CSRF mitigations such as **anti-CSRF tokens** or **strict session validation**.
- The **WAF was in passive (monitoring) mode**, logging the attempt but not actively preventing it. This increases the potential risk if similar attempts succeed in the future.
- Since the source IP does not have a negative reputation, it might be a **new attacker or compromised user system**, requiring continuous monitoring.

Splunk Query Used:

```
index="main" sourcetype="Imperva_WAF_Logs" "110.22.190.227"  
Action="Allowed" Threat_Name="Cross-Site Request Forgery"
```

Action Taken / Recommendations:

Security Engineering Team:

- Enable and enforce **WAF CSRF protection rules**.
- Implement input validation and block suspicious parameter manipulation.
- Ensure **anti-CSRF tokens** are integrated into critical workflows (e.g., account deletion).

Network Team:

- Closely monitor traffic from [redacted] for recurring activity.
- Restrict access to sensitive endpoints like **/accounts/delete** to authorized and authenticated users only.